

ShopSphere

S23 - Security Hardening, Audit and Compliance Readiness

Admin Portal

Platform-Specific Sprint Planning Document

This document intentionally defines only the behavior and delivery scope of the selected platform. It does not mix implementation details from the other platforms.

1. Sprint Definition

Sprint: S23 - Security Hardening, Audit and Compliance Readiness

Platform: Admin Portal

Application: ShopSphere

Objective: Implement only the admin-web behavior relevant to Security Hardening, Audit and Compliance Readiness; do not implement customer behavior in this document.

This sprint is complete only when the stated use cases, acceptance criteria and tests pass for this platform.

2. Business Use Cases

ID	Use Case	Actor	Precondition	Main Flow	Expected Result
UC-01	Audit critical mutation	Admin/system	Mutation is authorized	Record actor, action, object, old/new values where allowed, timestamp	Audit entry is immutable/traceable.
UC-02	Attempt privilege escalation	Attacker/tester	Low-privilege session	Call restricted API directly	Server rejects request and records security event where appropriate.

3. Detailed Implementation Plan

1. Verify every route/action enforces permission.
2. Hide sensitive fields by role.
3. Ensure destructive actions require confirmation and backend authorization.
4. Restrict audit visibility.

4. Data / State / Contract Scope

- No direct database changes. Data is accessed through backend APIs.

API / Integration Contract

- Consume the corresponding secured /api/v1 admin/customer operational APIs defined by the backend sprint document.

5. Rules and Expected Behavior

- The platform must rely on the backend as the source of truth for business rules.
- Do not expose stack traces, secrets or internal implementation details to end users.
- Handle loading, empty, validation and error states explicitly.
- Requests that can be retried must be safe from duplicate side effects where the feature requires idempotency.
- Ownership and authorization must be checked server-side for protected data.

6. Acceptance Criteria

- Only authorized admin roles can access the feature.
- Admin UI reflects server state and permission boundaries.
- Validation, loading, empty, error and confirmation states are implemented where relevant.
- No customer UI behavior is defined in this document.

7. Test Cases

TC	Scenario	Expected Result
TC-S23-01	Privilege escalation	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-02	Object ownership bypass	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-03	Brute force	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

TC	Scenario	Expected Result
TC-S23-04	Rate limit bypass	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-05	Tampered token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-06	Webhook replay	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-07	Sensitive error leakage	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-08	Audit write failure	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

8. Sprint Exit Checklist

- Implementation completed only for this platform.
- All primary and negative use cases pass.
- API contracts are implemented/consumed as defined.
- Validation and authorization tests pass.
- Loading/empty/error handling is verified where applicable.
- No critical or blocker defect remains.
- Automated tests pass in CI.
- Documentation and contract changes are committed.

9. Out of Scope for This Document

- Implementation behavior of Backend + DB. That behavior belongs in the separate S23 document for that platform.
- Implementation behavior of Customer Portal. That behavior belongs in the separate S23 document for that platform.